PROJECT 3 – CYBERSECURITY

Case Study: The 2017 Equifax Data Breach

Purpose: To demonstrate an understanding of cybersecurity vulnerabilities, their causes and risks, and responsible defensive practices for preventing similar incidents.

Case Background

Equifax, a major credit-reporting company, experienced a large-scale data breach in 2017. Attackers exploited a known vulnerability in Apache Struts, a software framework used by the company's web application. A security update was available, but the vulnerable system was not successfully patched. The incident exposed sensitive personal and financial information belonging to millions of people.

The case is useful for cybersecurity study because it demonstrates that security depends not only on finding vulnerabilities, but also on applying patches, verifying that security controls work, protecting credentials, monitoring systems, and responding to incidents.

1. What is the vulnerability?

The primary vulnerability was a known security weakness in Apache Struts, which was used by an Equifax web application. A security patch was available to address the vulnerability. However, the affected system remained unpatched and therefore exposed to attack.

The case also revealed weaknesses in security management, including inadequate verification that required patches had been installed and poor protection of certain administrative credentials.

2. How can it happen?

The incident occurred because a known vulnerability was not successfully remediated. Equifax had been notified about the Apache Struts vulnerability and instructed its personnel to patch affected systems. However, the company did not properly verify that the patch had been applied to the vulnerable system.

This demonstrates how a vulnerability can remain exploitable when organizations have weak patch-management processes, insufficient verification, or incomplete visibility into their systems and software.

3. What are the risks?

The attackers gained access to Equifax's network and sensitive databases. According to the U.S. Federal Trade Commission (FTC), the breach affected approximately 147 million people and exposed highly sensitive information.

Risk	Possible Impact
Identity theft	Stolen personal information can be used for fraudulent activities.
Financial fraud	Financial and payment information may be misused.
Privacy loss	Sensitive personal information can be exposed without authorization.
Reputational damage	Customers may lose trust in the organization.

Legal and financial consequences	The organization may face investigations, penalties, lawsuits, and remediation costs.

The FTC reported that the exposed information included names, dates of birth, Social Security numbers, and payment-card information. The sensitivity of this information made the breach particularly serious.

4. How can developers prevent it?

• **Apply security patches promptly:** Known vulnerabilities should be addressed within an appropriate risk-based timeframe.

• **Verify patches:** Teams should confirm that updates were actually installed on every affected system.

• **Maintain software inventories:** Organizations should know which applications, frameworks, libraries, and versions are running.

• **Protect credentials:** Administrative passwords and other sensitive credentials should never be stored in plain text.

• **Use least privilege:** Accounts and applications should receive only the permissions they need.

• **Monitor systems:** Security logs and network activity should be monitored for unusual behavior.

• **Test security controls:** Vulnerability scanning and security assessments should be performed regularly.

5. What security practices should be implemented?

Security Practice	Purpose
Regular patch management	Fix known software vulnerabilities before they can be exploited.
Vulnerability scanning	Identify weaknesses in applications, systems, and infrastructure.
Security testing	Detect security problems during development and before deployment.
Credential protection	Protect passwords, keys, tokens, and administrative credentials.
Least-privilege access	Limit what users and applications can access.
Network segmentation	Reduce the ability of attackers to move through a network after an initial compromise.
Security monitoring	Detect suspicious activity and potential intrusions.
Incident response planning	Provide a clear process for containing and recovering from security incidents.
Regular security audits	Verify that security policies and controls are operating effectively.
Security awareness training	Help employees recognize and respond to security risks.

Conclusion

The 2017 Equifax data breach demonstrates how a known software vulnerability can become a major cybersecurity incident when patch management and security verification are inadequate. The case emphasizes the importance of defensive security practices such as timely patching, vulnerability management, credential protection, least-privilege access, monitoring, and incident response. For developers and IT professionals, cybersecurity should be considered throughout the software and

system lifecycle rather than only after an incident occurs.

References

Federal Trade Commission. (2019). Equifax to pay $575 million as part of settlement related to 2017 data breach.

Federal Trade Commission. (2019). The $575 million Equifax settlement illustrates security basics for your business.

U.S. House Committee on Oversight and Government Reform. (2018). The Equifax data breach.